



Chapter 3 – Malware Analysis

Introduction to Malware Analysis

What is Malware Analysis?

Malware Analysis is the process of studying a malicious file, program, script, or process to understand:

- ✓ What the malware does
- ✓ How it infects a system
- ✓ What changes it makes
- ✓ How it communicates
- ✓ How to detect and remove it
- ✓ How to prevent future infections

A SOC Analyst or Malware Analyst investigates malware behavior after it enters a system.

Real-Life Example

Suppose an employee downloads a cracked version of Photoshop from an untrusted website.

Initially, everything appears normal.

However, in the background the malware may:

- Create malicious files
- Modify registry entries
- Create scheduled tasks
- Contact attacker-controlled servers
- Download additional malware

- Steal passwords
- Encrypt files

The analyst's job is to discover exactly what the malware is doing.

What Should Be Monitored During Malware Analysis?

When malware infects a machine, analysts monitor multiple activities.

File Activity Monitoring

Check whether malware is:

- Creating files
- Deleting files
- Modifying files
- Encrypting files
- Downloading files

Example

A ransomware sample may create hundreds of encrypted files within minutes.

Network Activity Monitoring

Monitor network packets to identify:

- Outbound connections
- Download attempts
- Command and Control (C2) communication

Questions to Ask

- ✓ Is the malware contacting an external server?
- ✓ Is data being uploaded?

- ✓ Is another payload being downloaded?
-

Command and Control (C2) Server

What is a C2 Server?

A Command and Control Server is an attacker-controlled server that communicates with infected machines.

The malware connects to the C2 server to:

- Receive commands
 - Download payloads
 - Upload stolen data
 - Receive updates
-

Real-Life Example

Imagine a thief remotely controlling a CCTV camera from another city. Similarly, attackers control infected machines through C2 servers.

Process Monitoring

Analysts investigate:

- Running Processes
- Child Processes
- Parent Processes
- Process Trees

Example

chrome.exe

└─ powershell.exe

└─ malware.exe

This would be suspicious because Chrome normally should not launch PowerShell.

Registry Persistence Analysis

What is Persistence?

Persistence means the malware ensures it launches every time Windows starts.

A common technique is modifying registry startup locations.

Common Registry Locations

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

HKLM\Software\Microsoft\Windows\CurrentVersion\Run

Example

The malware creates:

Updater = C:\Users\Admin\AppData\malware.exe

Now the malware starts automatically after every reboot.

Scheduled Task Analysis

Malware frequently creates scheduled tasks.

These tasks:

- Launch malware automatically
- Download payloads
- Re-establish persistence

Red Flag

If an unknown process creates:

☒ Run Registry Entries

OR

✓ Scheduled Tasks

It may be malware.

📌 Important Interview Point:

Unknown entries inside Run Registry locations or Task Scheduler are common persistence mechanisms used by malware.



MalwareBazaar

What is MalwareBazaar?

[MalwareBazaar](https://www.malwarebazaar.com/)

MalwareBazaar is a malware sample repository used by:

- SOC Analysts
 - Threat Researchers
 - Malware Analysts
-

What Information Can Be Found?

For each malware sample:

- ✓ Malware Name
 - ✓ Upload Date
 - ✓ SHA256 Hash
 - ✓ Signature Information
 - ✓ Malware Family
 - ✓ Tags
-

Using VirusTotal with MalwareBazaar

After obtaining the hash:

1. Copy SHA256 Hash
2. Open [VirusTotal](#)
3. Search the Hash

You can then view:

- Detection Results
- Antivirus Detections
- Network Activity
- Registry Activity
- File Relationships

Important Safety Rule ⚠

Malware samples should NEVER be executed on the host machine.

Always use:

- ✓ VMware
- ✓ VirtualBox
- ✓ Sandbox Environment

Types of Malware Analysis

There are two major types:

1 Static Malware Analysis

Definition

Static analysis means examining malware without executing it.

Analysts investigate:

- Source Code
 - Strings
 - Imports
 - DLLs
 - Metadata
 - PE Structure
-

Requirements

Usually requires:

- Programming Knowledge
 - Reverse Engineering Skills
 - Assembly Knowledge
-

Common Tools

- Strings
 - PEStudio
 - IDA
 - Ghidra
-

2 Dynamic Malware Analysis

Definition

Dynamic analysis means running malware in a controlled environment and observing behavior.

What is Monitored?

- File Creation
 - Registry Changes
 - Process Activity
 - Network Traffic
 - DLL Loading
-

Why Dynamic Analysis is More Popular?

Because malware behavior becomes visible during execution.

You can see:

- ✓ What it downloads
 - ✓ What files it creates
 - ✓ What registry entries it modifies
 - ✓ Which servers it contacts
-

🔧 Sysinternals Tools Used in Malware Analysis

Microsoft provides the Sysinternals toolkit.

Common SOC tools include:

- Autoruns
- Process Monitor
- Process Explorer
- TCPView

Sysinternals Suite

Autoruns

What is Autoruns?

Autoruns shows everything configured to start automatically.

Run:

autoruns.exe

as Administrator.

Why Use Autoruns?

It helps detect:

- ✓ Registry Run Entries
 - ✓ Startup Programs
 - ✓ Services
 - ✓ Drivers
 - ✓ Scheduled Tasks
 - ✓ Browser Extensions
-

Logon Tab

The Logon Tab shows applications that start when Windows boots.

Color Indicators in Autoruns

Yellow Entry

File entry exists but the file is missing.

Example:

Registry points to:

C:\malware.exe

but the file does not exist.

Red Entry

Often indicates suspicious or unverified entries.

Requires investigation.

Brown/Pinkish Entry

May indicate unsigned or suspicious components.

Important Rule

If an entry has:

 No Publisher

 No Verification Information

Investigate the file immediately.



Understanding DLL Files

What is a DLL?

DLL stands for:

Dynamic Link Library

A DLL contains reusable code used by applications.

Example

When Chrome needs audio functionality:

It uses:

audio.dll

When Word needs printing:

It may use:

print.dll

Applications import these DLLs instead of writing the functionality themselves.

DLL Injection Attack

What is DLL Injection?

An attacker creates a malicious DLL and tricks a legitimate application into loading it.

Example Scenario

Normal DLL:

print.dll

Malicious DLL:

print.dll

Same name.

Different functionality.

Instead of printing, the malicious DLL may:

- Encrypt files
 - Create scheduled tasks
 - Download malware
 - Contact C2 servers
-

How DLL Injection Works

1. Malware places a fake DLL.
2. Application loads the DLL.
3. Malicious code executes.

4. Legitimate application unknowingly spreads malware.

DLL Search Order Hijacking

Windows searches DLLs in specific locations.

Normally:

C:\Windows\System32

is trusted.

Red Flag 🚩

If critical DLLs are loaded from:

AppData

Temp

ProgramData

instead of System32,

the DLL may be malicious.

Important Detection Rule

Legitimate Windows DLLs should generally load from:

C:\Windows\System32

If they load from:

C:\Users\User\AppData

investigate immediately.

Autoruns Important Tabs

Explorer Tab

Shows:

- File Explorer Extensions
 - Shell Extensions
 - Explorer Startup Components
-

Scheduled Tasks Tab

Shows all Task Scheduler entries.

Most legitimate entries originate from:

C:\Program Files

or

C:\Windows

Red Flag

Tasks launching from:

AppData

ProgramData

or unknown drives

may indicate malware.

Drivers Tab

Displays:

- Driver Name
- Publisher

- Path

Driver files usually use:

.sys

extension.

Boot Execute Tab

Shows components that execute during the boot process.

These start before the user logs in.

Malware Handling in Companies

Important SOC Rule

Do NOT immediately delete malware.

First collect evidence.

Evidence Collection

Always document:

- ☒ File Name
 - ☒ File Path
 - ☒ Hash Value
 - ☒ Registry Entries
 - ☒ Scheduled Tasks
 - ☒ Screenshots
 - ☒ Network Connections
-

Why?

Because evidence is required for:

- Incident Reports
 - Threat Intelligence
 - Future Detection
 - Legal Investigations
-

Process Monitor (ProcMon)

What is Process Monitor?

Process Monitor monitors process behavior in real time.

It tracks:

- File Activity
 - Registry Activity
 - Process Activity
 - Network Activity
-

Use Case

If you want to monitor:

msedge.exe

You can apply filters and watch exactly what the process does.

Process Explorer

What is Process Explorer?

Process Explorer is an advanced version of Task Manager.

Run as Administrator.

What Information Does It Show?

For every process:

- ✓ Parent Process
 - ✓ Child Process
 - ✓ Command Line
 - ✓ DLLs Loaded
 - ✓ Current Directory
 - ✓ Registry Startup Location
 - ✓ User Account
-

Additional Benefits

You can:

- Investigate suspicious processes
 - View process trees
 - Kill stubborn processes
-

Example

If Task Manager cannot terminate malware:

Process Explorer may successfully terminate it.



TCPView

What is TCPView?

TCPView displays all active network connections.

Run:

tcpview.exe

as Administrator.

Information Displayed

For each process:

- ✓ Process Name
 - ✓ Process ID (PID)
 - ✓ State
 - ✓ Local Address
 - ✓ Local Port
 - ✓ Remote Address
 - ✓ Remote Port
 - ✓ Create Time
-

Why Is TCPView Important?

It helps identify:

- C2 Communication
 - Malware Beaconing
 - Suspicious Connections
-

Example

Suppose:

Photoshop.exe

keeps contacting an unknown Russian IP every 5 minutes.

TCPView can reveal:

- When the connection started
- Destination IP

- Destination Port

This is a strong malware indicator.

Common Malware Locations

SOC Analysts frequently investigate:

AppData

Temp

ProgramData

These folders are commonly abused by malware.

Infection Scenario Explained

Suppose a user installs a cracked Photoshop version.

Step 1

User executes installer.

Step 2

Installer drops:

malware.js

into AppData.

Step 3

Creates:

- Run Registry Entry
- Scheduled Task

Step 4

User reboots machine.

Step 5

Registry launches malware automatically.

Step 6

Malware connects to C2 server.

Step 7

Additional payloads are downloaded.

This is a classic persistence attack.

Explorer.exe Incident Handling

What Happens If Explorer.exe Is Killed?

Taskbar disappears.

Desktop icons disappear.

Windows interface vanishes.

Why Malware Uses Explorer.exe

Many malware samples inject themselves into Explorer.exe because:

- It is trusted.
 - Users rarely terminate it.
 - Killing it affects the desktop.
-

Recovery Method

Open Task Manager

Press:

Ctrl + Shift + Esc

Run CMD

Choose:

File → Run New Task

Launch:

cmd.exe

Restart Explorer

Run:

explorer.exe

Desktop and taskbar return.

Interview Questions

Q1. What is malware persistence?

Persistence is a technique that allows malware to survive system reboots and automatically execute when the system starts.

Q2. What is DLL Injection?

DLL Injection is a technique where a malicious DLL is loaded into a legitimate process to execute malicious code.

Q3. What is the difference between Static and Dynamic Malware Analysis?

Static Analysis	Dynamic Analysis
No execution	Malware executed
Code inspection	Behavior observation
Reverse engineering	Runtime analysis

Q4. Which Sysinternals tools are commonly used in malware analysis?

- ✓ Autoruns
 - ✓ Process Monitor
 - ✓ Process Explorer
 - ✓ TCPView
-

Q5. What is a C2 Server?

A Command and Control (C2) Server is an attacker-controlled server used to communicate with infected systems.
